Dépendances numériques et résilience organisationnelle : une grille d'analyse du risque cyber d'origine géopolitique

Analyse conceptuelle et étude de cas multiples — Implications pour la gouvernance du risque cyber (GRC)

Auteur : Innocent Twagirumukiza | **Date :** 13 octobre 2026 | **Type :** Analyse conceptuelle / étude de cas
Domaine : Cybersécurité, GRC, résilience organisationnelle

RÉSUMÉ

Contexte. Les organisations dépendent de ressources numériques, industrielles et algorithmiques qu'elles ne contrôlent que partiellement. Dans un contexte de tensions géopolitiques, ces dépendances peuvent devenir des vecteurs de propagation du risque cyber et affecter la continuité des activités, au-delà du périmètre technique du système d'information.

Question. Dans quelles conditions une dépendance externe devient-elle un vecteur de propagation du risque d'origine géopolitique, et comment l'intégrer à la gouvernance du risque cyber ?

Méthode. Analyse conceptuelle et étude de cas multiples, qualitative et documentaire. Six situations examinées selon une grille en cinq dimensions (dépendance, concentration, substitution, propagation, résilience), avec un niveau de preuve pour la dimension géopolitique (attribuée, documentée, non démontrée, scénario).

Résultats. Les cas illustrent des mécanismes distincts. La criticité d'une dépendance croît avec la concentration et la durée de substitution. La géopolitique n'est démontrée que pour une partie des cas.

Implications. Une grille opérationnelle et des propositions de gouvernance sont formulées pour le RSSI et les fonctions GRC, en lien avec NIS2, DORA et la boîte à outils UE sur la chaîne d'approvisionnement TIC.

Mots-clés : dépendances numériques ; résilience organisationnelle ; risque cyber ; géopolitique ; GRC ; chaîne d'approvisionnement ; interdépendance ; intelligence artificielle.

ABSTRACT. Background: organisations depend on digital, industrial and algorithmic resources they only partially control. Question: under what conditions does an external dependency become a vector of geopolitically driven risk propagation? Method: conceptual analysis and multiple qualitative documentary case study with a five-dimension grid and levels of geopolitical evidence. Findings: distinct mechanisms; criticality grows with concentration and substitution lead time; geopolitics demonstrated only for part of the cases. Implications: operational grid and GRC proposals linked to NIS2, DORA and the EU ICT supply chain toolbox.

Keywords: digital dependencies; organisational resilience; cyber risk; geopolitics; GRC; supply chain; interdependence; artificial intelligence.

1. Introduction

1.1. Contexte et problème

Les conflits contemporains ne se jouent plus seulement sur les champs de bataille. Ils se prolongent dans les réseaux, les chaînes d'approvisionnement, les infrastructures critiques et les systèmes d'information (Conseil de l'Union européenne, 2026). Pour les organisations, le risque cyber ne se limite plus aux actifs qu'elles administrent directement : postes, serveurs, applications, réseaux, identités et données.

Une organisation peut être touchée sans être une cible politique ou militaire, simplement parce qu'elle appartient à un écosystème : cloud, télécoms, prestataires informatiques, logiciels étrangers, énergie, banques, sous-traitance. L'ENISA documente l'exploitation croissante des dépendances numériques et des points critiques des chaînes d'approvisionnement (ENISA, 2025 ; ENISA, 2026). La boîte à outils de l'UE pour la sécurité de la chaîne d'approvisionnement des TIC formalise une approche commune pour identifier et atténuer ces risques (Commission européenne / Groupe de coopération SRI, 2026).

Le raisonnement « Suis-je une cible ? » devient insuffisant. La question pertinente devient : de quoi mon activité dépend-elle, et qui pourrait utiliser cette dépendance contre moi ?

1.2. Question de recherche et contribution

La question centrale est la suivante : *dans quelles conditions une dépendance externe devient-elle un vecteur de propagation du risque d'origine géopolitique, et comment l'intégrer à la gouvernance du risque cyber ?*

Trois sous-questions : (1) comment distinguer le périmètre technique de sécurité du périmètre de dépendance ? (2) quels mécanismes relient dépendance, perturbation et continuité d'activité dans des situations documentées ? (3) comment formuler une grille opérationnelle pour le RSSI et la GRC ? La contribution est triple : cadre conceptuel ; grille d'analyse en cinq dimensions appliquée à six situations ; propositions de gouvernance formulées comme recommandations de l'auteur.

1.3. Statut des énoncés et plan

Les faits tirés des rapports institutionnels et des sources primaires sont présentés comme **constats documentés**. Les liens avec la géopolitique des dépendances relèvent d'une **interprétation**. Les recommandations de la section 7 constituent des **propositions de l'auteur**. Un incident aux conséquences économiques n'est pas automatiquement une opération géopolitique : la dimension géopolitique reçoit un niveau de preuve explicite (attribuée, documentée, non démontrée, scénario). Plan : cadre théorique (2), cadre conceptuel (3), méthodologie (4), analyse des cas (5), synthèse (6), implications GRC (7), limites (8), conclusion (9).

2. Cadre théorique et état de l'art

2.1. Interdépendance et coercition

Farrell et Newman (2019) ont conceptualisé l'« interdépendance weaponisée » : les réseaux économiques et technologiques peuvent devenir des instruments de coercition lorsque des acteurs contrôlent des goulets d'étranglement. Keohane et Nye (2012) avaient souligné que l'interdépendance asymétrique crée des rapports de pouvoir. Ces approches éclairent les dépendances numériques : la concentration de l'offre logicielle, cloud ou matérielle peut créer des points de pression stratégiques, sans que chaque perturbation soit une attaque cyber.

2.2. Cyber, conflit et menaces hybrides

La littérature sur le cyberconflit (Rid, 2013 ; Buchanan, 2020) invite à distinguer attribution, intention et effet. Les rapports ENISA et les conclusions du Conseil de l'UE sur les menaces hybrides documentent le chevauchement des campagnes cyber, d'espionnage, de désinformation et de pression économique (ENISA, 2025 ; ENISA, 2026 ; Conseil de l'Union européenne, 2026). Les infrastructures civiles

apparaissent comme des cibles ou des effets collatéraux dans des contextes de confrontation.

2.3. Risque systémique et chaînes d'approvisionnement

Perrow (1999) a analysé les accidents dans les systèmes complexes et étroitement couplés. Christopher et Peck (2004) et Sheffi (2005) ont développé la résilience des chaînes d'approvisionnement face aux chocs. La littérature sur la chaîne logicielle prolonge ces analyses au domaine numérique : un maillon faible peut propager une perturbation à l'ensemble d'un écosystème.

2.4. Résilience organisationnelle

Hollnagel, Woods et Leveson (2006) définissent la résilience comme la capacité à ajuster le fonctionnement avant, pendant et après une perturbation. Le NIST SP 800-160 vol. 2 et l'ISO 22301 insistent sur l'anticipation, la résistance, la récupération et l'adaptation. Ces cadres restent souvent centrés sur les actifs internes ; l'intégration explicite des dépendances géopolitiques reste limitée.

2.5. Cadre réglementaire

NIS2, DORA, CRA et AI Act structurent les obligations européennes. La boîte à outils UE sur la chaîne d'approvisionnement TIC (2026) propose une approche commune pour identifier, évaluer et atténuer les risques, y compris les dépendances à des fournisseurs à haut risque (Commission européenne / Groupe SRI, 2026). Ces textes traitent les dépendances de manière sectorielle ou technique.

2.6. Lacune identifiée

La littérature et les textes réglementaires documentent menaces, chaînes d'approvisionnement et résilience, mais proposent peu de cadres opérationnels permettant de (a) distinguer périmètre technique et périmètre de dépendance, (b) évaluer la criticité selon des dimensions observables, et (c) attribuer un niveau de preuve à la dimension géopolitique sans assimiler toute perturbation à une opération étatique.

3. Cadre conceptuel

3.1. Périmètre technique de sécurité et périmètre de dépendance

Le **périmètre technique de sécurité** désigne les systèmes et actifs sur lesquels l'organisation peut exercer directement des mesures de protection. Le **périmètre de dépendance** englobe les ressources et acteurs dont l'indisponibilité ou la compromission peut empêcher l'organisation de remplir ses missions. Le second n'est pas réductible au premier.

3.2. Conditions de criticité d'une dépendance

Une dépendance devient critique lorsque plusieurs conditions sont réunies : (1) concentration de l'offre ; (2) difficulté de substitution ; (3) délai de remplacement important ; (4) faible maîtrise de la technologie ; (5) exposition à des décisions politiques ou tensions internationales. Une dépendance commerciale n'est pas automatiquement une vulnérabilité exploitable.

3.3. Typologie des dépendances

Cinq types : **logicielle** (éditeurs, mises à jour, supervision) ; **industrielle / OT** (systèmes de contrôle, énergie) ; **intermédiaire de service** (paiement, cloud, prestataires centraux) ; **matérielle** (composants, terres rares, semi-conducteurs) ; **algorithmique** (modèles d'IA, calcul, données). Un scénario illustratif (équipements techniques connectés) peut éclairer le type industriel sans entrer dans le corpus de cas documentés.

3.4. Grille d'analyse en cinq dimensions

- **Dépendance** — Quelles ressources externes sont indispensables ?
- **Concentration** — Plusieurs fonctions reposent-elles sur un même fournisseur, technologie ou zone ?
- **Substitution** — Quel délai pour remplacer (jours, semaines, mois) ?
- **Propagation** — Qui d'autre est affecté (filiales, partenaires, secteur) ?
- **Résilience** — Quelles fonctions en mode dégradé, combien de temps, avec quels moyens ?

Niveau de preuve géopolitique : *attribuée* ; *documentée* ; *non démontrée* ; *scénario*.

3.5. Propositions

P1. La criticité d'une dépendance croît avec la concentration de l'offre et la durée de substitution. **P2.** L'interconnexion amplifie la propagation d'une perturbation au-delà de l'organisation initialement exposée. **P3.** Une perturbation économique ou technique n'implique pas, à elle seule, une opération géopolitique ; le niveau de preuve doit être établi séparément.

4. Méthodologie

Design. Étude de cas multiples, qualitative, documentaire (Yin, 2018). Objectif : analyse comparative de mécanismes, non généralisation statistique. **Sélection.** Variation selon type de dépendance, nature de l'acteur et caractère cyber ou non. Inclusion : faits documentés par sources primaires ou institutionnelles. Exclusion du corpus principal : incidents non sourcés de manière indépendante. **Sources.** Primaires (rapports d'entreprises, CERT, agences) et secondaires (ENISA, GAO, IEA, NIST, Conseil UE). **Codage.** Faits ; dépendance ; mécanisme ; niveau de preuve géopolitique ; grille ; enseignement. **Validité.** Biais de sélection, sources secondaires, absence d'entretiens.

5. Analyse des cas

5.1. NotPetya / Maersk (2017)

Faits documentés. En juin 2017, NotPetya s'est propagé internationalement après introduction dans une chaîne de distribution logicielle en Ukraine. A. P. Moller-Maersk a confirmé l'impact. Dans son rapport annuel 2017, Maersk estimait les pertes entre 250 et 300 millions de dollars (A. P. Moller–Maersk, 2018). **Dépendance / mécanisme.** Logicielle et chaîne logistique ; propagation en cascade vers opérations physiques et partenaires. **Niveau de preuve géopolitique.** Attribuée (contexte russo-ukrainien, attributions officielles). **Grille.** Concentration (logiciel commun) ; substitution difficile à court terme ; propagation transnationale forte. **Enseignement.** La résilience dépend aussi de la capacité à contenir les effets d'une attaque qui ne visait pas nécessairement l'organisation en priorité.

5.2. SolarWinds (2020)

Faits. Compromission Orion ; code SUNBURST via mises à jour légitimes. CERT-FR a documenté l'incident (CERT-FR, 2020). **Mécanisme.** Chaîne de confiance des mises à jour ; privilèges étendus. **Preuve géopolitique.** Documentée (enjeux d'espionnage). **Enseignement.** La sécurité ne peut pas reposer exclusivement sur la confiance accordée aux composants logiciels.

5.3. Réseau électrique ukrainien (2015)

Faits. Cyberattaque de décembre 2015 ; coupures touchant environ 225 000 clients pendant une à six heures ; compromission d'ICS (U.S. Department of Energy / CISA). **Mécanisme.** OT ; effet physique sur un service essentiel. **Preuve.** Documentée. **Enseignement.** Protéger une infrastructure critique, c'est préserver sa capacité à fournir un service même lorsque les systèmes numériques sont compromis.

5.4. Change Healthcare (2024)

Faits. Rançongiciel de février 2024 ; perturbations à grande échelle ; pertes estimées à 874 millions de dollars (U.S. GAO, 2024). **Mécanisme.** Intermédiaire numérique central ; indisponibilité sectorielle. **Preuve géopolitique.** Non démontrée (impact systémique documenté ; intention géopolitique non établie). **Enseignement.** Un fournisseur peut devenir un point de défaillance commun sans attaque directe contre chaque organisation.

5.5. Terres rares (2025)

Faits. Concentration chinoise : ~60 % production minière, ~91 % raffinée, ~94 % aimants (2024) ; restrictions d'exportation d'avril 2025 ; difficultés d'approvisionnement pour des constructeurs automobiles (IEA, 2025). **Mécanisme.** Matérielle ; restriction d'accès par décision souveraine. **Preuve.** Documentée (hors cyberattaque). **Enseignement.** La résilience numérique dépend aussi de ressources matérielles influencées par les rapports de puissance internationaux.

5.6. Intelligence artificielle et calcul

Faits. Intégration de l'IA dans les opérations malveillantes (ENISA, 2025) ; taxonomie des attaques sur l'apprentissage automatique (Vassilev et al., 2024) ; contrôles d'exportation de technologies de calcul avancé (U.S. BIS, 2025). **Mécanisme.** Algorithmique et matérielle (GPU, cloud, modèles) ; surface d'attaque propre. **Preuve.** Documentée pour les contrôles d'export et la compétition technologique. **Enseignement.** La résilience à l'ère de l'IA suppose de maîtriser les dépendances numériques, matérielles et algorithmiques.

6. Synthèse et discussion

Cas	Type	Mécanisme	Preuve géo.
NotPetya/Maersk	Logicielle	Propagation transnationale	Attribuée
SolarWinds	Confiance logicielle	Chaîne de mise à jour	Documentée
Réseau élec. UA	OT	Effet physique	Documentée
Change Healthcare	Intermédiaire	Concentration sectorielle	Non démontrée
Terres rares	Matérielle	Restriction d'accès	Documentée (hors cyber)
IA / calcul	Algorithmique	Accès, surface d'attaque	Documentée (partielle)

6.2–6.5. Résultats, propositions, réglementation, géopolitique

(1) Une dépendance est particulièrement sensible lorsqu'elle est difficile à remplacer et conditionne une fonction essentielle (soutien à P1). (2) L'interconnexion amplifie les conséquences (soutien à P2). (3) Les vulnérabilités résultent d'attaques, de concentrations ou de décisions commerciales ; elles ne doivent pas être assimilées (soutien à P3). P1 et P2 sont cohérentes avec les cas, sans validation statistique. P3 est essentielle méthodologiquement.

NIS2, DORA et la boîte à outils UE imposent des exigences de gestion des risques fournisseurs. La grille proposée les prolonge en explicitant substitution, propagation et niveau de preuve géopolitique. La géopolitique est démontrée pour une partie des cas seulement (NotPetya, contexte ukrainien, terres rares, contrôles d'export IA) ; pour d'autres elle reste interprétation ou non démontrée.

7. Implications pour la GRC (propositions de l'auteur)

Ces propositions ne constituent pas des conclusions empiriques.

- **Cartographier les dépendances réelles** — concentration, délais de substitution — au-delà des questionnaires de conformité.
- **Intégrer la dimension géopolitique** sur facteurs observables (restrictions, tensions, concentration industrielle), non la seule nationalité.
- **Tester le mode dégradé** (indisponibilité 48 h, une semaine, un mois).
- **Étendre la continuité d'activité** aux dépendances numériques et matérielles externes (lien ISO 22301).
- **Traiter la chaîne d'approvisionnement de l'IA** — modèles, cloud, GPU, réversibilité, fonctionnement sans le service externe.
- **Gouvernance transversale** — RSSI, GRC, continuité, intelligence économique. Question : si une dépendance critique disparaissait demain, l'organisation pourrait-elle continuer à remplir ses missions ?

8. Limites et pistes de recherche

Limites. Corpus restreint (six situations) ; sources souvent secondaires ; pas d'entretiens ni de validation empirique quantitative ; sujet en évolution rapide. **Pistes.** Entretiens avec des RSSI ; méthode Delphi sur les indicateurs de criticité ; opérationnalisation quantitative de la grille ; applications sectorielles (finance, santé, énergie) ; comparaison internationale des approches réglementaires.

9. Conclusion

La résilience cyber d'une organisation ne dépend pas uniquement de sa capacité à protéger ses systèmes, mais également de sa capacité à identifier, évaluer et compenser les dépendances critiques qui conditionnent la continuité de ses activités dans un environnement géopolitique instable.

Cet article a proposé un cadre conceptuel, une grille d'analyse et une application documentaire à six situations, en distinguant constats, interprétation et propositions. La cyber-résilience, dans cette perspective, consiste non seulement à empêcher la crise d'entrer dans l'organisation, mais à pouvoir continuer à fonctionner lorsqu'elle est déjà là — y compris lorsque la perturbation naît d'une dépendance située hors du périmètre technique du système d'information.

Déclarations. *L'auteur déclare l'absence de conflit d'intérêts et de financement spécifique. Les données sont des sources publiques citées. Des outils d'assistance rédactionnelle ont été utilisés ; le contenu analytique relève de la responsabilité de l'auteur.*

Références

1. A. P. Moller–Maersk. (2018). *Annual Report 2017*. https://www.maersk.com/
2. Buchanan, B. (2020). *The Hacker and the State*. Harvard University Press.
3. CERT-FR. (2020, mise à jour 2021). *Présence de code malveillant dans SolarWinds Orion* (CERTFR-2020-ALE-026). https://www.cert.ssi.gouv.fr/
4. Christopher, M., & Peck, H. (2004). Building the resilient supply chain. *International Journal of Logistics Management*, 15(2), 1–13.
5. Commission européenne / Groupe de coopération SRI. (2026, 13 février). *Boîte à outils pour améliorer la sécurité de la chaîne d'approvisionnement des TIC*. https://digital-strategy.ec.europa.eu/fr/library/toolbox-improve-ict-supply-chain-security
6. Conseil de l'Union européenne. (2026, 16 mars). *Council adopts conclusions on advancing the EU's capacity to counter hybrid threats* (192/26). https://www.consilium.europa.eu/en/press/press-releases/2026/03/16/council-adopts-conclusions-on-advancing-the-eu-s-capacity-to-counter-hybrid-threats/
7. ENISA. (2025). *ENISA Threat Landscape 2025*. https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025
8. ENISA. (2026). *ENISA Threat Landscape 2026*. https://www.enisa.europa.eu/publications/enisa-threat-landscape-2026
9. Farrell, H., & Newman, A. L. (2019). Weaponized interdependence. *International Security*, 44(1), 42–79.
10. Hollnagel, E., Woods, D. D., & Leveson, N. (Eds.). (2006). *Resilience Engineering*. Ashgate.
11. International Energy Agency. (2025). *With new export controls on critical minerals, supply concentration risks become reality*. https://www.iea.org/
12. Keohane, R. O., & Nye, J. S. (2012). *Power and Interdependence* (4th ed.). Longman.
13. Perrow, C. (1999). *Normal Accidents*. Princeton University Press.
14. Rid, T. (2013). *Cyber War Will Not Take Place*. Oxford University Press.
15. Sheffi, Y. (2005). *The Resilient Enterprise*. MIT Press.
16. U.S. Department of Commerce, BIS. (2025). Framework for Artificial Intelligence Diffusion. *Federal Register*, 90 FR 4544.
17. U.S. Department of Energy / CISA. Documentation on the 2015 Ukrainian power grid attack. https://www.cisa.gov/
18. U.S. GAO. (2024). *Healthcare Cybersecurity* (GAO-25-107755). https://www.gao.gov/
19. Vassilev, A., Oprea, A., Fordyce, A., & Andersen, H. (2024). *Adversarial Machine Learning* (NIST AI 100-2e2023). https://doi.org/10.6028/NIST.AI.100-2e2023
20. Yin, R. K. (2018). *Case Study Research and Applications* (6th ed.). Sage.

Comment citer : Twagirumukiza, I. (2026). Dépendances numériques et résilience organisationnelle : une grille d'analyse du risque cyber d'origine géopolitique. *Analyse conceptuelle*. https://twagirumukiza.github.io/Geopolitique-et-cybersecurite/au-dela-du-systeme-d-information.html